

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 1 頁，共 22 頁

單選題 15 題，複選題 5 題，題組題 5 題（佔 100%）

B	1. 公司取得應徵人員的個人資料時，下列何項行為違反個人資料保護法？ (A) 說明取得資料之使用期限 (B) 請其放棄申請其個人資料複製本之權利 (C) 說明個人資料的使用對象 (D) 告知個人資料使用之方式
C	2. 依據 ISO/ IEC 27001:2022 之中，關於溝通與傳達的內容，組織應決定相關於資訊安全管理系統之內部及外部溝通或傳達的需要，「不」包括下列何項？ (A) 溝通或傳達事項 (B) 溝通或傳達對象 (C) 溝通或傳達地點 (D) 溝通或傳達方式
B	3. 金管會於 2024 年 7 月發布《金融業導入零信任架構參考指引》，將導入措施分為四級（Level I - IV）。若在資源存取時，將「時間、地點、設備合規狀態」等動態屬性納入授權審核條件，並可對異常樣態進行動態撤銷、限縮存取或即時告警，請問該作法屬於下列哪一級的資安管控措施？ (A) 第一級 靜態指標 (B) 第二級 融入動態指標 (C) 第三級 以即時指標為主 (D) 第四級 最佳化整合指標

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 2 頁，共 22 頁

A C D	4. 近年資通安全事件與日俱增，為使上市公司充分揭露重大資安事件，保障投資人知的權利，證交所已修訂重大訊息問答集明確規範資安事件之「重大性」標準。關於造成公司重大損害或影響之描述，下列哪些最正確？（複選） (A) 媒體報導公司發生資通安全事件，可能影響投資人之投資決策 (B) 僅公司核心資通系統、官方網站等，遭駭客攻擊入侵致無法營運或正常提供服務 (C) 公司有個資、內部文件檔案資料外洩之虞等情事 (D) 公司對造成損害或影響之評估結果（如財務損失），可能影響投資人之投資決策
C	5. 【題組 1】情境如附圖所示。身為該醫療中心的資安長（CISO），情境在發現勒索軟體活動的當下，根據台灣《資通安全管理法》的規定，您的團隊第一小時內最優先的法定應辦事項為下列何項？ 一家被政府依《資通安全管理法》核定為「關鍵基礎設施提供者（Critical Infrastructure Provider）」的區域醫療中心，其資訊環境為混合雲架構。院內核心的「電子病歷系統（EHR）」部署於本地資料中心，而新推出的「遠距醫療諮詢平台」則採用雲端原生技術，並整合了第三方開發的預約排程模組。為提升效率，開發團隊被允許在配發的公務筆電上，使用生成式 AI 輔助開發。某日上午，資安監控中心（SOC）的 AI 驅動偵測系統發出警報，顯示 EHR 主機出現勒索軟體加密行為，同時發現攻擊源頭來自一台開發人員的筆電，該筆電因執行了含有惡意程式碼的 AI 輔助工具而遭入侵。 (A) 立即支付勒索贖金以最快速度回復系統，避免影響病患照護 (B) 全面斷開醫院對外網路，阻止威脅擴散並進行內部損害評估 (C) 依據事件分級，完成初步損害評估與判斷，並於一小時內通報主管機關 (D) 召集所有資訊人員，優先搶救被加密的電子病歷資料庫

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 3 頁，共 22 頁

- B 6. 【題組 1】情境如附圖所示。身為該醫療中心的資安長 (CISO)，為有效控制損害並避免攻擊者在混合雲環境內部橫向移動，下列何種安全架構規劃原則在此情境下最能發揮作用？

一家被政府依《資通安全管理法》核定為「關鍵基礎設施提供者 (Critical Infrastructure Provider)」的區域醫療中心，其資訊環境為混合雲架構。院內核心的「電子病歷系統 (EHR)」部署於本地資料中心，而新推出的「遠距醫療諮詢平台」則採用雲端原生技術，並整合了第三方開發的預約排程模組。為提升效率，開發團隊被允許在配發的公務筆電上，使用生成式 AI 輔助開發。某日上午，資安監控中心 (SOC) 的 AI 驅動偵測系統發出警報，顯示 EHR 主機出現勒索軟體加密行為，同時發現攻擊源頭來自一台開發人員的筆電，該筆電因執行了含有惡意程式碼的 AI 輔助工具而遭入侵。

- (A) 強化邊界防火牆規則，嚴格過濾所有進出醫院網路的流量
- (B) 導入零信任安全架構 (Zero Trust Architecture, ZTA)，在內網實施微切分 (Micro-segmentation)
- (C) 要求所有員工每三十天更換一次高強度密碼，並進行資安教育訓練
- (D) 集中所有伺服器日誌至本地的資安訊息與事件管理系統 (SIEM) 進行分析

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 4 頁，共 22 頁

- B 7. 【題組 1】情境如附圖所示。身為該醫療中心的資安長（CISO），在事件後的改善會議上，考量到醫院的預算限制與營運持續性，下列何項針對「供應鏈安全」的長期風險處理策略最為務實且具成本效益？

一家被政府依《資通安全管理法》核定為「關鍵基礎設施提供者（Critical Infrastructure Provider）」的區域醫療中心，其資訊環境為混合雲架構。院內核心的「電子病歷系統（EHR）」部署於本地資料中心，而新推出的「遠距醫療諮詢平台」則採用雲端原生技術，並整合了第三方開發的預約排程模組。為提升效率，開發團隊被允許在配發的公務筆電上，使用生成式 AI 輔助開發。某日上午，資安監控中心（SOC）的 AI 驅動偵測系統發出警報，顯示 EHR 主機出現勒索軟體加密行為，同時發現攻擊源頭來自一台開發人員的筆電，該筆電因執行了含有惡意程式碼的 AI 輔助工具而遭入侵。

- (A) 要求所有第三方軟體供應商提供其產品的完整原始碼進行原始碼掃描
- (B) 建立軟體物料清單（Software Bill of Materials, SBOM）管理機制，並導入工具持續監控已知漏洞
- (C) 全面禁止使用任何開源軟體與第三方模組，所有系統均自行開發
- (D) 要求第三方軟體供應商皆簽署最高額度資安保險

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 5 頁，共 22 頁

A B C	8. 【題組 1】情境如附圖所示。身為該醫療中心的資安長 (CISO)，為了建構一個同時兼具彈性與韌性的安全防護體系，防止此類結合供應鏈與內部人員的攻擊再次發生，下列哪些安全架構與管理措施應被納入改善計畫？（複選）
	一家被政府依《資通安全管理法》核定為「關鍵基礎設施提供者 (Critical Infrastructure Provider)」的區域醫療中心，其資訊環境為混合雲架構。院內核心的「電子病歷系統 (EHR)」部署於本地資料中心，而新推出的「遠距醫療諮詢平台」則採用雲端原生技術，並整合了第三方開發的預約排程模組。為提升效率，開發團隊被允許在配發的公務筆電上，使用生成式 AI 輔助開發。某日上午，資安監控中心 (SOC) 的 AI 驅動偵測系統發出警報，顯示 EHR 主機出現勒索軟體加密行為，同時發現攻擊源頭來自一台開發人員的筆電，該筆電因執行了含有惡意程式碼的 AI 輔助工具而遭入侵。 (A) 在所有端點（包含開發者筆電）部署端點偵測與應變（Endpoint Detection and Response, EDR）系統 (B) 制定並落實嚴格的特權存取管理（Privileged Access Management, PAM）政策，採最小權限原則 (C) 為所有關鍵系統（如 EHR）的存取啟用基於風險評估的適應性多因子認證（Adaptive MFA） (D) 要求所有遠端工作模式，均需配置單向閘道傳輸器，以確保作業安全
C	9. 關於零信任架構（ZTA）的描述，下列何者較「不」正確？ (A) 相當適用於防禦內部攻擊或受到入侵後的橫向移動 (B) 存取資源時由政策執行點（Policy Enforcement Point, PEP）向政策決策點（Policy Decision Point, PDP）詢問是否應該允許存取資源 (C) 詳細的 ZTA 架構說明描述於 NIST SP800-217 中 (D) 端對端的加密通訊使得零信任架構的部署更具挑戰

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 6 頁，共 22 頁

D	10. 某企業為防止內部人員濫用權限，設計了資訊系統的權限分工制度。下列何項作法「最符合」職務區隔（Separation of Duties, SOD）之原則？ (A) 系統管理員擁有新增、查詢、刪除與審核所有交易紀錄的權限 (B) 員工可依需求申請額外權限，經由直屬主管自動核准後立即生效 (C) 部門主管在系統中直接新增自己以及下屬之出勤與加班紀錄，並同時進行審核 (D) 資料輸入作業由 A 員工負責，資料審核與最終送出作業由 B 員工執行
C	11. 一間跨國製造企業正在評估如何處理量子運算（Quantum Computing）對其現有資料加密儲存構成的長期風險。該企業儲存的設計圖與專利資料需保密數十年。考量到未來「先擷取後解密（Harvest Now, Decrypt Later）」的威脅，下列何種風險處理策略在當前最具前瞻性與成本效益考量？ (A) 立即將所有加密系統升級為領導廠商宣稱的「抗量子」專有演算法 (B) 採取風險接受策略，認定量子運算在資料生命週期內不會成熟 (C) 啟動混合加密模式，同時使用傳統加密演算法與標準化的後量子密碼學（Post-Quantum Cryptography, PQC）演算法 (D) 將風險完全轉移，僅透過購買網路安全保險來應對未來可能的資料洩露

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 7 頁，共 22 頁

A B D	12. 為了防禦日益逼真的深度偽造 (Deepfake) 攻擊，組織應採取結合技術與程序的綜合性防禦策略。下列哪些措施屬於此類策略？（複選） (A) 採用具備活體偵測 (Liveness Detection) 功能的生物辨識系統 (B) 建立一個獨立的、高可信度的通訊管道（如緊急簡訊群組），用於驗證高風險指令 (C) 禁止所有員工使用社交媒體 (D) 針對財務、人事等敏感操作，實施職務區隔 (Segregation of Duties, SoD) 與多重審批流程
C	13. 【題組 2】情境如附圖所示。請問為了有效防範 AI 深度偽造技術的語音與影像攻擊，降低組織同仁受騙將公司的款項匯出造成組織的營運損失，下列何項推動組合較為有效？ 近年來，人工智慧的應用有效的協助企業組織完成許多艱難的任務，節省大量的人力。然而，結合深度偽造技術 (Deepfake) 的語音與影像攻擊，使詐騙效果更高。攻擊者可精準模仿組織高層的聲音或影像，誘使受害者放下警戒、依指示行動，導致重大資安風險與營運損失。企業高層要求身為資安長的您規劃一系列的強化機制，以避免組織同仁受騙將公司的款項匯出造成組織的營運損失。 資安部門據此推動以下控制措施： (1) 阻擋存取深度偽造工具或相關不良內容網站的使用。 (2) 企業導入影像辨識、聲音辨識或 AI 模組，增加深度偽造攻擊的防禦能力。 (3) 教育員工辨識深度偽造攻擊（如假冒上司語音指令、影像假訊息等）。 (4) 財務與會計系統導入多因子認證 (Multi-Factor Authentication, MFA)，以降低匯款人員身份遭到盜用。 (5) 電子郵件系統強化安全性，導入電子郵件系統的資料儲存加密技術。 (6) 加強職務區隔 (Segregation of Duties, SoD)；超過一定金額的匯款額度需要經過主管複核同意後始得匯款。 (7) 採用專有視訊會議系統導入多因子認證，封鎖非公司認可的專有視訊會議系統開會。 (A) (2)(5) (B) (1)(3) (C) (6)(7) (D) (4)(5)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 8 頁，共 22 頁

- D 14. 【題組 2】情境如附圖所示。請問為了有效防範 AI 深度偽造的語音與影像攻擊，降低組織同仁受到詐騙將公司的款項匯出造成組織的營運損失，下列何項推動組合最為無效？

近年來，人工智慧的應用有效的協助企業組織完成許多艱難的任務，節省大量的人力。然而，結合深度偽造技術（Deepfake）的語音與影像攻擊，使詐騙效果更高。攻擊者可精準模仿組織高層的聲音或影像，誘使受害者放下警戒、依指示行動，導致重大資安風險與營運損失。企業高層要求身為資安長的您規劃一系列的強化機制，以避免組織同仁受騙將公司的款項匯出造成組織的營運損失。

資安部門據此推動以下控制措施：

- (1)阻擋存取深度偽造工具或相關不良內容網站的使用。
- (2)企業導入影像辨識、聲音辨識或 AI 模組，增加深度偽造攻擊的防禦能力。
- (3)教育員工辨識深度偽造攻擊（如假冒上司語音指令、影像假訊息等）。
- (4)財務與會計系統導入多因子認證（Multi-Factor Authentication, MFA），以降低匯款人員身份遭到盜用。
- (5)電子郵件系統強化安全性，導入電子郵件系統的資料儲存加密技術。
- (6)加強職務區隔（Segregation of Duties, SoD）；超過一定金額的匯款額度需要經過主管複核同意後始得匯款。
- (7)採用專有視訊會議系統導入多因子認證，封鎖非公司認可的專有視訊會議系統開會。

- (A) (1)(2)
- (B) (2)(3)
- (C) (3)(4)
- (D) (4)(5)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 9 頁，共 22 頁

- B 15. 【題組 2】情境如附圖所示。資安長要求除了前述控制外，為了強化 AI 治理，導入 ISO 42001 人工智慧管理系統 (Artificial Intelligence Management System, AIMS)，請問在導入 AIMS 過程中，下列何項組合與 AI 治理較具關聯？

近年來，人工智慧的應用有效的協助企業組織完成許多艱難的任務，節省大量人力。然而，結合深度偽造技術 (Deepfake) 的語音與影像攻擊，使詐騙效果高。攻擊者可精準模仿組織高層的聲音或影像，誘使受害者放下警戒、依指示動，導致重大資安風險與營運損失。企業高層要求身為資安長的您規劃一系列強化機制，以避免組織同仁受騙將公司的款項匯出造成組織的營運損失。

資安部門據此推動以下控制措施：

- (1)阻擋存取深度偽造工具或相關不良內容網站的使用。
- (2)企業導入影像辨識、聲音辨識或 AI 模組，增加深度偽造攻擊的防禦能力。
- (3)教育員工辨識深度偽造攻擊 (如假冒上司語音指令、影像假訊息等)。
- (4)財務與會計系統導入多因子認證 (Multi-Factor Authentication, MFA)，以降低匯款人員身份遭到盜用。
- (5)電子郵件系統強化安全性，導入電子郵件系統的資料儲存加密技術。
- (6)加強職務區隔 (Segregation of Duties, SoD)；超過一定金額的匯款額度需要經過主管複核同意後始得匯款。
- (7)採用專有視訊會議系統導入多因子認證，封鎖非公司認可的專有視訊會議系統開會。

- (A) (1)(5)
- (B) (2)(3)
- (C) (3)(4)
- (D) (5)(6)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 10 頁，共 22 頁

A B C	16. 【題組 2】情境如附圖所示。在導入影像辨識、聲音辨識或 AI 模組，為了確保導入系統的可信任性（Trustworthiness），應考量下列哪些項目？（複選） 近年來，人工智慧的應用有效的協助企業組織完成許多艱難的任務，節省大量的人力。然而，結合深度偽造技術（Deepfake）的語音與影像攻擊，使詐騙效果更高。攻擊者可精準模仿組織高層的聲音或影像，誘使受害者放下警戒、依指示行動，導致重大資安風險與營運損失。企業高層要求身為資安長的您規劃一系列的強化機制，以避免組織同仁受騙將公司的款項匯出造成組織的營運損失。資安部門據此推動以下控制措施： (1)阻擋存取深度偽造工具或相關不良內容網站的使用。 (2)企業導入影像辨識、聲音辨識或 AI 模組，增加深度偽造攻擊的防禦能力。 (3)教育員工辨識深度偽造攻擊（如假冒上司語音指令、影像假訊息等）。 (4)財務與會計系統導入多因子認證（Multi-Factor Authentication, MFA），以降低匯款人員身份遭到盜用。 (5)電子郵件系統強化安全性，導入電子郵件系統的資料儲存加密技術。 (6)加強職務區隔（Segregation of Duties, SoD）；超過一定金額的匯款額度需要經過主管複核同意後始得匯款。 (7)採用專有視訊會議系統導入多因子認證，封鎖非公司認可的專有視訊會議系統開會。 (A) AI 強韌度（AI Robustness） (B) AI 可靠度（AI Reliability） (C) AI 可控性（AI Controllability） (D) AI 系統速度（AI System Speed）
A	17. 參考美國國家標準研究院（NIST）與 ISO/IEC 62443 相關規範，營運技術（Operational Technology, OT）網路環境，包含製造業、醫療業等，在設計上的原則下列何者最為適切？ (A) 要區隔資訊環境及作業環境 (B) 可以透過主機型防火牆做區隔 (C) 可以共用同一台目錄服務跟檔案伺服器 (D) OT 環境比較封閉可以不用更新軟體弱點

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 11 頁，共 22 頁

C	18. 某業者近期頻繁遭受勒索軟體攻擊，其攻擊路徑多數是透過員工端點電腦感染後擴散。在強化端點安全防護時，除了傳統防毒軟體外，可評估導入下列何種技術以有效偵測並阻擋未知勒索軟體行為？ (A) 加強網路層防火牆規則設定 (B) 於核心網路部署入侵偵測系統（Intrusion Detection System, IDS） (C) 導入端點偵測與回應（Endpoint Detection & Response, EDR）解決方案 (D) 導入增強寫入過濾器（Enhanced Write Filter, EWF）等系統保護機制
C	19. 某智慧製造工廠計畫導入零信任安全架構（Zero Trust Architecture, ZTA）以保護其營運技術（Operational Technology, OT）網路。相較於傳統的資訊技術（Information Technology, IT）環境，在 OT 場域中實施 ZTA 時，面臨的最大挑戰通常是什麼？ (A) 使用者身分多元，難以統一管理 (B) 缺乏足夠的網路頻寬來處理持續的驗證請求 (C) 大量老舊的工業控制系統（ICS）與設備不支援現代化的身分驗證協定 (D) OT 環境中的資料流量過於龐大，難以進行深度封包檢測（Deep Packet Inspection, DPI）
A C	20. 企業可實際應用下列哪些防護措施，以協助降低勒索軟體的風險？（複選） (A) 定期執行異地備份重要資料 (B) 禁用所有資料加密功能以防止勒索軟體加密資料 (C) 使用應用程式白名單機制 (D) 僅依賴作業系統的內建安全功能

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 12 頁，共 22 頁

B	21. 【題組 3】情境如附圖所示。公司於國內希望統一控管對外連線，所有的網際網路流量可以被監控，下列何項方案最「不」適切？ 某上市公司因覺得國內市場飽和，同時考量降低生產成本，以求增加其產品的競爭力與組織獲利，故公司國內於南部設有公司總部，並於附近有一生產基地，另於東南亞 V 國有一生產基地，並於美國及歐洲有營業據點，以擴展公司的業務。 (A) 於總部及生產基地各自佈署防火牆並集中管理規則與日誌 (B) 總部及生產基地各自租賃網際網路服務存取網際網路直接對外連線 (C) 租用專線（Leased Line）連接總部與生產基地，對外連線統一從總部出口 (D) 生產基地透過站台對站台虛擬私人網路（Site-to-Site VPN），將流量全部導向公司總部
B	22. 【題組 3】情境如附圖所示。國內總公司因應海外客戶的要求，其特別重視個資保護，故要求公司需要通過 ISO 27701 隱私資訊安全驗證，請問下列何項措施最「不」適切？ 某上市公司因覺得國內市場飽和，同時考量降低生產成本，以求增加其產品的競爭力與組織獲利，故公司國內於南部設有公司總部，並於附近有一生產基地，另於東南亞 V 國有一生產基地，並於美國及歐洲有營業據點，以擴展公司的業務。 (A) 審視 ISO/IEC 27001 資訊安全管理驗證的範圍是否符合需求 (B) 積極尋求通過 BS 10012 個人資訊管理驗證 (C) 選擇業務部門優先導入 ISO/IEC 27701 資訊安全管理驗證 (D) 選擇生產基地優先導入 ISO/IEC 27701 資訊安全管理驗證

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 13 頁，共 22 頁

A	23. 【題組 3】情境如附圖所示。因關稅考量，公司決定於美國增設一生產基地，以提高商品的競爭力，原營業據點將遷移至生產基地，相關業務人員採遠端辦公，下列何者措施有助於公司集中控管資訊系統同時可以符合遠端辦公的需求？ 某上市公司因覺得國內市場飽和，同時考量降低生產成本，以求增加其產品的競爭力與組織獲利，故公司國內於南部設有公司總部，並於附近有一生產基地，另於東南亞 V 國有一生產基地，並於美國及歐洲有營業據點，以擴展公司的業務。 (A) 導入精簡用戶端配合虛擬桌面基礎架構 (VDI) (B) 導入零信任架構 (ZTA) (C) 在所有筆電啟用 BitLocker 全磁碟加密 (D) 宣導員工使用私人電腦進行遠端連線
A B D	24. 【題組 3】情境如附圖所示。歐洲地區的業務人員多採遠距辦公，由公司配發筆記型電腦供員工使用，主要採用 Windows 10 作業系統，請問下列哪些措施最能降低公司機密外流的風險？（複選） 某上市公司因覺得國內市場飽和，同時考量降低生產成本，以求增加其產品的競爭力與組織獲利，故公司國內於南部設有公司總部，並於附近有一生產基地，另於東南亞 V 國有一生產基地，並於美國及歐洲有營業據點，以擴展公司的業務。 (A) 為員工提供虛擬私人網路 (VPN) 以加密存取內部資源 (B) 啟用 BitLocker 磁碟加密功能 (C) 作業系統禁止使用無線區域網路 (D) 導入精簡用戶端配合雲端桌面

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 14 頁，共 22 頁

C	25. 請參閱附圖作答。一組織的系統開發單位進行資安風險評鑑前，將釐清所有資通系統與組織業務二者間的關聯性，以作為資安風險管理之範疇與邊界。在定義範疇與邊界時，應考量之因素包含附圖中的哪些事項較為適切？ 1. 組織架構、營運目標、策略及政策 2. 適用之法令、法規及契約要求 3. 組織整體風險管理作法 4. 系統管理者的期望 5. 組織內資訊及資通系統資產及相對應之控制措施 (A) 2、3 (B) 2、4、5 (C) 1、2、3、5 (D) 1、3、4、5
C	26. 有關風險評鑑流程（風險識別、風險分析、風險評估）的描述，下列何者最為適切？ (A) 組織在識別風險時，若風險來源不可控制，可不予考量 (B) 風險分析係評估事件發生之可能性與影響，且該事件僅有單一來源、單一後果 (C) 風險評估是將風險分析結果與組織的風險準則比較，以決定哪些風險需採取額外的控制措施 (D) 組織決策時無法完整納入利害關係人意見，因此僅須由適當層級決議確認風險評估結果

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 15 頁，共 22 頁

A	27. 在當前地緣政治衝突加劇的背景下，一家位於關鍵基礎設施領域（如電力、水利）的國營企業，下列何類攻擊的威脅最為巨大？ (A) 具備國家背景支持、以癱瘓或情蒐為目的的進階持續性威脅（Advanced Persistent Threat, APT）組織 (B) 為了政治訴求而進行網路塗鴉的駭客行動主義者（Hacktivist） (C) 尋找並回報漏洞以獲取獎金的白帽駭客 (D) 以竊取個人資料在暗網販售為目的的普通網路罪犯
A B D	28. 進行電子郵件系統風險評估時，下列哪些選項為可用性評估的考量因素？（複選） (A) 電子郵件系統的備援方式 (B) 最適可用人數的評估 (C) 電子郵件系統管理者登入密碼之管制方式 (D) 電子郵件系統負載平衡運作方式

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 16 頁，共 22 頁

- C 29. 【題組 4】情境如圖所示。XYZ 公司將導入資訊安全管理系統（Information Security Management System, ISMS）標準，依循 ISO 27005 及 ISO31000 進行風險管理時，各項風險管理作業述簡要列示如：【1.風險回應、2.建立全景、3.風險分析及評估、4.風險識別、5.風險評鑑、6.風險處理、7.記錄及報告】。並且依標準將「監視與審查」與「溝通及諮詢」作業貫穿於整個風險管理流程之中。請問下列何者為正確的風險管理流程順序？

XYZ 公司為一晶片設計公司，經最高管理階層會議決議，擬在 3~5 年間達成上市的目標，並於今年開始提交永續報告書，其中資訊安全管理策略議題章節草擬規劃如下【圖 1】，資訊安全架構如下【圖 2】。

【圖 1】

策略議題	2023年進度、成果	短期目標（1-3年）	中長期目標（3-10年）
資訊安全管理	- 導入ISO 27001資訊安全管理系統標準 - 資安管理範圍納入供應商範圍，邀集供應商舉辦資安訓練，提升供應鏈廠商資安防護能力。 - 頒布「產品安全管理政策」，各產品線產品必須從需求、設計、編碼、測試、交付、維護等不同產品開發階段，落實執行「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」程序。 - 實施各產品線每季執行PSDLC稽核，並發出報告做為實行成效與改進的依據，達到產品安全品質目標。 - 建立外部威脅情報蒐集程序，定期發布與公司產品安全相關情資訊息給各BU事業群參考，並分析潛在風險與可能影響，發揮早期預警功用。 - 建置全公司模糊測試平臺與品質標準，整合模糊測試工具與管理系統，確保各產品線能夠依循一致流程，達到安全品質要求。	- 預計取得ISO 27001 認證 - 預計取得車載資安國際標準TISAX認證標章。 - 修訂公司IP資安保護政策，確保遵循IP轉移規範與網路使用規範保障資訊安全。 - 拓展資安管理至供應鏈，強化企業資安合規性。 - 修訂派遣外包合約，提高派遣外包人員資訊安全意識及強化規範，以降低相關風險。 - 所有產品線完成導入開源第三方軟體註冊/審核/掃描/修補流程，降低開源第三方軟體安全漏洞風險。 - 集中管理全產品線安全通報事件，有效落實漏洞追蹤與修補。	- 建置資訊安全監控中心（Security Operations Center, SOC），即時偵測資訊安全事件與告警的機制，並定期檢測資訊系統架構。 - 建立軟體自動化安全檢測技術，持續提升資安檢測能力。 - 建立軟體物料清單（SBOM）系統機制，清楚掌握軟體內容組成/版本/來源/漏洞等資訊，滿足高安全強度合規需求。 - 針對產品安全漏洞通報訊息進行分析，強化現行產品開發流程不足之處，持續提升產品安全品質。

【圖 2】

資訊安全管理架構

XYZ科技為管理資訊安全風險之目的，成立資訊安全委員會，由共同營運長及公司執行副總經理暨財務長擔任召集人，定期檢討資通安全、產品安全以及資料安全的執行情況，每半年至少召開一次，並得視資安風險管理需要隨時召開會議，並每年定期向董事會報告資訊安全檢查情形。



- (A) 13456
(B) 54317
(C) 24367
(D) 25431

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 17 頁，共 22 頁

- C 30. 【題組 4】情境如圖所示。承上題，依 XYZ 科技的資訊安全委員會在評量資安策略及資安管理架構時，請問下列何項資訊安全管理範疇設定描述最「不」適切？

XYZ 公司為一晶片設計公司，經最高管理階層會議決議，擬在 3~5 年間達成上市目標，並於今年開始提交永續報告書，其中資訊安全管理策略議題章節草擬規劃如下【圖 1】，資訊安全架構如下【圖 2】。

【圖 1】

策略議題	2023年進度、成果	短期目標（1-3年）	中長期目標（3-10年）
資訊安全管理	- 導入ISO 27001資訊安全管理系統標準 - 資安管理範疇納入供應商範圍，邀集供應商舉辦資安訓練，提升供應廠商資安防護能力。 - 頒布「產品安全管理政策」，各產品線產品必須從需求、設計、編碼、測試、交付、維護等不同產品開發階段，落實執行「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」程序。 - 實施各產品線每季執行PSDLC稽核，並發出報告做為實行成效與改進的依據，達到產品安全品質目標。 - 建立外部威脅情報蒐集程序，定期發布與公司產品安全相關情報資訊給各BU事業群參考，並分析潛在風險與可能影響，發揮早期預警功用。 - 建置全公司模糊測試平臺與品質標準，整合模糊測試工具與管理系統，確保各產品線能夠依循一致流程，達到安全品質要求。	- 預計取得ISO 27001 認證 - 預計取得車載資安國際標準TISAX認證標準。 - 修訂公司IP資安保護政策，確保遵循IP轉移規範與網路使用規範保障資訊安全。 - 拓展資安管理至供應鏈，強化企業資安合規性。 - 修訂派遣外包合約，提高派遣外包人員資訊安全意識及強化規範，以降低相關風險。 - 所有產品線完成導入開源第三方軟體註冊/審核/掃描/修補流程，降低開源第三方軟體安全漏洞風險。 - 集中管理全產品線安全通報事件，有效落實漏洞追蹤與修補。	- 建置資訊安全監控中心（Security Operations Center, SOC），即時偵測資訊安全事件與告警的機制，並定期檢測資訊系統架構。 - 建立軟體自動化安全檢測技術，持續提升資安檢測能量。 - 建立軟體物料清單（SBOM）系統機制，清楚掌握軟體內容組成/版本/來源/漏洞等資訊，滿足高安全強度合規需求。 - 針對產品安全漏洞通報訊息進行分析，強化現行產品開發流程不足之處，持續提升產品安全品質。

【圖 2】

資訊安全管理架構

XYZ 科技為管理資訊安全風險之目的，成立資訊安全委員會，由共同營運長及公司執行副總經理暨財務長擔任召集人，定期檢討資通安全、產品安全以及資料安全的執行情況，每半年至少召開一次，並得視資安風險管理需要隨時召開會議，並每年定期向董事會報告資訊安全檢查情形。



- (A) 包含有形與無形的資訊資產、人員、營運流程皆應納入風險評鑑項目之中
- (B) 針對供應商資安作業，可於合約要求簽署必要的保密協議及資訊安全事項，並遵循公司資訊安全政策
- (C) 產品不屬資訊資產不需列入資安風險評鑑項目之中，應由產品部門依循公司定訂的-「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」程序操作即可
- (D) 資訊安全管理需定期參考國際安全標準及銷售地之法律法規要求，並更新公司的相關管理辦法與程序

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 18 頁，共 22 頁

- A 31. 【題組 4】情境如圖所示。承上題，XYZ 公司風險評估後，決定導入「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」管理制度與定期稽核，此程序主要是屬於下列那一類型的風險處理措施？

XYZ 公司為一晶片設計公司，經最高管理階層會議決議，擬在 3~5 年間達成上市的目標，並於今年開始提交永續報告書，其中資訊安全管理策略議題章節草擬規劃如下【圖 1】，資訊安全架構如下【圖 2】。

【圖 1】

策略議題	2023年進度、成果	短期目標（1-3年）	中長期目標（3-10年）
資訊安全管理	- 導入ISO 27001資訊安全管理系統標準 - 資安管理範圍納入供應商範圍，邀集供應商舉辦資安訓練，提升供應鏈廠商資安防護能力。 - 頒布「產品安全管理政策」，各產品線產品必須從需求、設計、編碼、測試、交付、維護等不同產品開發階段，落實執行「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」程序。 - 實施各產品線每季執行PSDLC稽核，並發出報告做為實行成效與改進的依據，達到產品安全品質目標。 - 建立外部威脅情報蒐集程序，定期發布與公司產品安全相關情資訊息給各BU事業群參考，並分析潛在風險與可能影響，發揮早期預警功用。 - 建置全公司模糊測試平臺與品質標準，整合模糊測試工具與管理系統，確保各產品線能夠依循一致流程，達到安全品質要求。	- 預計取得ISO 27001 認證 - 預計取得車載資安國際標準TISAX認證標章。 - 修訂公司IP資安保護政策，確保遵循IP轉移規範與網路使用規範保障資訊安全。 - 拓展資安管理至供應鏈，強化企業資安合規性。 - 修訂派遣外包合約，提高派遣外包人員資訊安全意識及強化規範，以降低相關風險。 - 所有產品線完成導入開源第三方軟體註冊/審核/掃描/修補流程，降低開源第三方軟體安全漏洞風險。 - 集中管理全產品線安全通報事件，有效落實漏洞追蹤與修補。	- 建置資訊安全監控中心（Security Operations Center, SOC），即時偵測資訊安全事件與告警的機制，並定期檢測資訊系統架構。 - 建立軟體自動化安全檢測技術，持續提升資安檢測能量。 - 建立軟體物料清單（SBOM）系統機制，清楚掌握軟體內容組成/版本/來源/漏洞等資訊，滿足高安全強度合規需求。 - 針對產品安全漏洞通報訊息進行分析，強化現行產品開發流程不足之處，持續提升產品安全品質。

【圖 2】

資訊安全管理架構

XYZ科技為管理資訊安全風險之目的，成立資訊安全委員會，由共同營運長及公司執行副總經理暨財務長擔任召集人，定期檢討資通安全、產品安全以及資料安全的執行情況，每半年至少召開一次，並得視資安風險管理需要隨時召開會議，並每年定期向董事會報告資訊安全檢查情形。



- (A) 風險修改（Risk Modification）
(B) 風險避免（Risk Avoidance）
(C) 風險保留（Risk Retention）
(D) 風險分擔（Risk Sharing）

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 19 頁，共 22 頁

B
C
D

32. 【題組 4】情境如圖所示。承上題，XYZ 公司在開發新產品時所面臨的資安風險，請問有下列哪些方式可以導入處理？（複選）

XYZ 公司為一晶片設計公司，經最高管理階層會議決議，擬在 3~5 年間達成上市的目標，並於今年開始提交永續報告書，其中資訊安全管理策略議題章節草擬規劃如下【圖 1】，資訊安全架構如下【圖 2】。

【圖 1】

策略議題	2023年進度、成果	短期目標（1-3年）	中長期目標（3-10年）
資訊安全管理	- 導入ISO 27001資訊安全管理系統標準 - 資安管理範圍納入供應商範圍，邀集供應商舉辦資安訓練，提升供應鏈廠商資安防護能力。 - 頒布「產品安全管理政策」，各產品線產品必須從需求、設計、編碼、測試、交付、維護等不同產品開發階段，落實執行「產品安全開發生命週期（Product Security Development Life Cycle, PSDLC）」程序。 - 實施各產品線每季執行PSDLC稽核，並發出報告做為實行成效與改進的依據，達到產品安全品質目標。 - 建立外部威脅情報蒐集程序，定期發布與公司產品安全相關情資訊息給BU事業群參考，並分析潛在風險與可能影響，發揮早期預警功用。 - 建置全公司模塊測試平臺與品質標準，整合模塊測試工具與管理系統，確保各產品線能夠依循一致流程，達到安全品質要求。	- 預計取得ISO 27001 認證 - 預計取得車載資安國際標準TISAX認證標章。 - 修訂公司IP資安保護政策，確保遵循IP轉移規範與網路使用規範保障資訊安全。 - 拓展資安管理至供應鏈，強化企業資安合規性。 - 修訂派遣外包合約，提高派遣外包人員資訊安全意識及強化規範，以降低相關風險。 - 所有產品線完成導入開源第三方軟體註冊/審核/掃描/修補流程，降低開源第三方軟體安全漏洞風險。 - 集中管理全產品線安全通報事件，有效落實漏洞追蹤與修補。	- 建置資訊安全監控中心（Security Operations Center, SOC），即時偵測資訊安全事件與告警的機制，並定期檢測資訊系統架構。 - 建立軟體自動化安全檢測技術，持續提升資安檢測能力。 - 建立軟體物料清單（SBOM）系統機制，清楚掌握軟體內容組成/版本/來源/漏洞等資訊，滿足高安全強度合規需求。 - 針對產品安全漏洞通報訊息進行分析，強化現行產品開發流程不足之處，持續提升產品安全品質。

【圖 2】

資訊安全管理架構

XYZ科技為管理資訊安全風險之目的，成立資訊安全委員會，由共同營運長及公司執行副總經理暨財務長擔任召集人，定期檢討資通安全、產品安全以及資料安全的執行情況，每半年至少召開一次，並得視資安風險管理需要隨時召開會議，並每年定期向董事會報告資訊安全檢查情形。



- (A) 當產品開發測試階段完成後再處理所有安全問題
- (B) 產品安全事件管理上需通知客戶相關風險並提供產品安全修補，並納入新產品的設計考量之中
- (C) 產品開設計階段進行威脅建模以分析潛在漏洞
- (D) 使用靜態程式碼分析工具檢查程式碼安全

B

33. 有關在選擇風險處理選項時可參考之因素，下列何項敘述「有誤」？

- (A) 應考量組織的目標來選擇風險處理選項
- (B) 應考量組織的業務壓力來選擇風險處理選項
- (C) 應考量組織所訂之風險準則來選擇風險處理選項
- (D) 應考量組織可用資源來選擇風險處理選項

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 20 頁，共 22 頁

D	34. 有關風險處理的描述，下列何者最為適切？ (A) 該資產的使用者，即為需決定風險處理方式的角色 (B) 資產擁有者不需要參與識別其資產相關聯之風險 (C) 風險評鑑進行完成後，再決定建立風險接受準則以進行後續風險處理 (D) 需考量風險評鑑的結果，由風險擁有者於風險處理的選項中，選擇適切之方式
B	35. 在網站憑證使用風險對策上，下列何者最「不」適切？ (A) 外部網站憑證必須要納入資訊資產，確保其可用性 (B) 內部系統網站，也必須要採用外部簽發的憑證 (C) 網站憑證的簽發單位也必須納入風險評估的一環 (D) 網站憑證必須要設定到期提醒之巡查流程
A B D	36. 有關風險處理計畫之敘述，下列哪些項目最為適切？（複選） (A) 風險處理計畫之目的為規範如何實施選定之風險處理選項 (B) 風險處理計畫應明確鑑別風險處理實施之順序 (C) 風險處理計畫之內容必須包含所有外部關注方之回饋 (D) 風險處理計畫之內容應包含風險當責者及核准與實施風險處理計畫之人員

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 21 頁，共 22 頁

C	37. 【題組 5】情境如圖所示。駭客刪除備份後發佈勒索訊息，請問下列何項行為的描述最為適切？ 2025 年 2 月時，A 公司及其關係企業遭受駭客組織發動的勒索攻擊。該攻擊發生於週末夜間，駭客成功潛入企業核心系統，刪除了所有備份，並聲稱竊取了 1TB 的機密資料。隔天清晨，企業官網首頁被竄改，發布了駭客的勒索訊息，要求在 24 小時內支付未公開的贖金，否則將外洩資料並摧毀企業聲譽。此次攻擊事件對 A 公司造成重大損失，公司核心系統 ERP、CRM…等業務系統全面癱瘓，生產與供應鏈亦因而停擺。 (A) 偽裝攻擊 (B) 服務阻斷 (C) 勒索攻擊 (D) 社交工程
C	38. 【題組 5】情境如圖所示。關於此事件之風險處理，下列何者最「不」合適？ 2025 年 2 月時，A 公司及其關係企業遭受駭客組織發動的勒索攻擊。該攻擊發生於週末夜間，駭客成功潛入企業核心系統，刪除了所有備份，並聲稱竊取了 1TB 的機密資料。隔天清晨，企業官網首頁被竄改，發布了駭客的勒索訊息，要求在 24 小時內支付未公開的贖金，否則將外洩資料並摧毀企業聲譽。此次攻擊事件對 A 公司造成重大損失，公司核心系統 ERP、CRM…等業務系統全面癱瘓，生產與供應鏈亦因而停擺。 (A) 風險降低 (Risk Reduction) (B) 風險避免 (Risk Avoidance) (C) 風險接受 (Risk Acceptance) (D) 風險轉移 (Risk Transfer)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

卷號：I21-4201

考試日期：114 年 8 月 23 日

第 22 頁，共 22 頁

D	39. 【題組 5】情境如圖所示。若 A 公司未來購買資安保險是屬於下列何種風險處理？ 2025 年 2 月時，A 公司及其關係企業遭受駭客組織發動的勒索攻擊。該攻擊發生於週末夜間，駭客成功潛入企業核心系統，刪除了所有備份，並聲稱竊取了 1TB 的機密資料。隔天清晨，企業官網首頁被竄改，發布了駭客的勒索訊息，要求在 24 小時內支付未公開的贖金，否則將外洩資料並摧毀企業聲譽。此次攻擊事件對 A 公司造成重大損失，公司核心系統 ERP、CRM…等業務系統全面癱瘓，生產與供應鏈亦因而停擺。 (A) 風險降低 (Risk Reduction) (B) 風險避免 (Risk Avoidance) (C) 風險接受 (Risk Acceptance) (D) 風險轉移 (Risk Transfer)
A B C	40. 【題組 5】情境如圖所示。針對此事件，A 公司實施下列哪些的安全控制措施，可以協助有效降低風險？（複選） 2025 年 2 月時，A 公司及其關係企業遭受駭客組織發動的勒索攻擊。該攻擊發生於週末夜間，駭客成功潛入企業核心系統，刪除了所有備份，並聲稱竊取了 1TB 的機密資料。隔天清晨，企業官網首頁被竄改，發布了駭客的勒索訊息，要求在 24 小時內支付未公開的贖金，否則將外洩資料並摧毀企業聲譽。此次攻擊事件對 A 公司造成重大損失，公司核心系統 ERP、CRM…等業務系統全面癱瘓，生產與供應鏈亦因而停擺。 (A) 實施多層備份策略 (B) 使用零信任網路架構 (C) 將備份系統與主網分離 (D) 定期刪除備份檔案